

ĐẠI HỌC QUỐC GIA TP HCM
TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN



**Hướng Dẫn Cài Đặt Và Sử Dụng Hệ Thống Hybrid
Certificate Authority Trên Avalanche Fuji Testnet**

Môn học: Mã hóa ứng dụng

Sinh viên thực hiện:

Lưu Đức Toàn	23120095
Phạm Quốc Nam Anh	23120111
Nguyễn Xuân Duy	23120121
Đào Nguyễn Nguyên	23120306

Giáo viên hướng dẫn:

Trương Toàn Thịnh
Lương Vĩ Minh

Ngày 31 tháng 5 năm 2026

Mục lục

1	Hướng dẫn sử dụng	2
1.1	Cài đặt Web Application	2
1.2	Claim Faucet và Chuẩn bị Ví Deployer	2
1.3	Triển khai Smart Contract	3
1.4	Ủy quyền cho Ví Admin	3
1.5	Đăng ký và Đăng nhập	4
1.6	Quy trình sử dụng dành cho Client	5
1.7	Quy trình quản trị dành cho Admin	6
2	Báo cáo kỹ thuật	8
2.1	Đặt vấn đề	8
2.2	Phân tích yêu cầu hệ thống	8
2.3	Thiết kế hệ thống	9
2.4	Thiết kế chức năng	10
2.4.1	Đăng ký tài khoản	10
2.4.2	Sinh cặp khoá RSA	10
2.4.3	Tạo CSR	10
2.4.4	Phê duyệt chứng thư	10
2.4.5	Thu hồi chứng thư	10
2.5	Công nghệ sử dụng	10
2.6	Bảo mật hệ thống	10
2.6.1	Bảo mật tài khoản	10
2.6.2	Xác thực và phân quyền	10
2.6.3	Bảo mật chứng thư số	11
2.6.4	Nhật ký hệ thống	11
3	Link demo	11

1 Hướng dẫn sử dụng

1.1 Cài đặt Web Application

Dưới đây là các bước để cài đặt và chạy ứng dụng web.

Yêu cầu hệ thống:

- **Node.js** (v18 trở lên)
- **Yarn**
- **Foundry**

Các bước thực hiện:

1. **Clone:**

```
git install https://github.com/kyries-uni-projects/Applied-Cryptography.git
cd Applied-Cryptography/server
```

2. **Cài đặt thư viện:**

```
yarn install
```

3. **Khởi tạo Prisma Client:**

```
yarn db:generate
```

4. **Cấu hình file .env:**

```
cp .env.example .env
```

5. **Khởi tạo Database SQLite:** push database Prisma vào file SQLite:

```
yarn db:push
```

6. **Seed dữ liệu mặc định:** tự động tạo cấu hình CA mặc định và tài khoản Admin gốc của hệ thống:

```
yarn db:seed
```

1.2 Claim Faucet và Chuẩn bị Ví Deployer

Để triển khai Smart Contract và thực hiện giao dịch trên mạng Avalanche Fuji Testnet, bạn bắt buộc phải có đồng AVAX (Testnet) làm phí gas.

1. **Cài đặt Ví:** Thêm mạng **Avalanche Fuji Testnet** vào ví MetaMask của bạn.
2. **Truy cập Faucet:** Vào trang [Avalanche Testnet Faucet](#).
3. **Nhận AVAX Testnet:** Sao chép địa chỉ ví MetaMask của bạn (ví này gọi là Deployer Wallet) và dán vào trang Faucet để nhận AVAX.
4. **Lấy Private Key:** Export Private Key của ví này từ MetaMask. Chuỗi Private Key này sẽ được sử dụng cho biến `$DEPLOYER_PRIVATE_KEY`.

Lưu ý quan trọng: Nếu không đủ gas, các thao tác này sẽ thất bại.

- Hãy đảm bảo **Ví Admin** luôn có đủ số dư AVAX để thực hiện các thao tác: Approve, Issue, Renew, Revoke chứng chỉ.
- Hãy đảm bảo **Ví Client** có đủ AVAX trước khi tạo CSR hoặc yêu cầu thu hồi.

1.3 Triển khai Smart Contract

Smart contract `CertificateRegistry.sol` giúp lưu trữ hashes của các yêu cầu cấp chứng chỉ, chứng chỉ đã cấp và danh sách thu hồi chứng chỉ (CRL) một cách minh bạch, bất biến.

1. Chuyển vào thư mục chứa smart contracts:

```
cd smart-contracts
```

2. Tải dependencies:

```
git submodule update --init --recursive
```

3. Compile:

```
forge build
```

4. Deploy:

```
forge script script/DeployCertificateRegistry.s.sol \
  --rpc-url https://api.avax-test.network/ext/bc/C/rpc \
  --broadcast --private-key $DEPLOYER_PRIVATE_KEY
```

Quan trọng: Sau khi deploy thành công, sao chép giá trị ở **Contract Address** trên terminal và dán vào biến `$CERTIFICATE_REGISTRY_ADDRESS`.

```
##### fuji
[Success] Hash: 0x948065c8de294140066f9fd3ebd817f9dc54a489c12f00401ddd28588131db23
Contract Address: 0x98D40502345838C9CF6694C5E33666B8f119a3De
Block: 55899633
Paid: 0.00348165286834861 ETH (3165139 gas * 1.09999999 gwei)

[Success] Sequence #1 on fuji | Total Paid: 0.00348165286834861 ETH (3165139 gas * avg 1.09999999 gwei)

=====
ONCHAIN EXECUTION COMPLETE & SUCCESSFUL.
```

1.4 Ủy quyền cho Ví Admin

Hệ thống backend tự động tạo ra một **Ví gốc của CA (CA Root Wallet)** bằng thuật toán sinh ví dựa trên root private key của CA. Ta bắt buộc phải **cấp quyền admin trên smart contract** cho địa chỉ ví backend này để admin có quyền tương tác với smart contract.

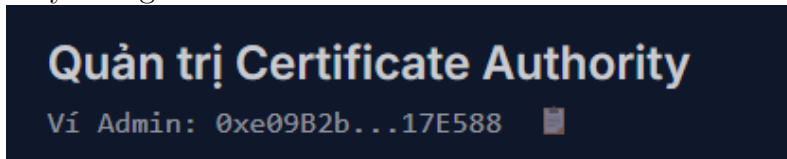
1. Khởi chạy ứng dụng Web:

```
yarn dev
```

Sau đó truy cập <http://localhost:3000> và đăng nhập bằng tài khoản admin mặc định:

- **Username:** admin
- **Password:** admin123

2. Lấy địa chỉ Ví Backend: Trên thanh điều hướng của giao diện Admin, bạn sẽ thấy thông tin “Ví Admin”.



3. Cấp quyền Admin trên Smart Contract: Sử dụng cast và ví Deployer để gọi hàm addAdmin:

```
cast send <YOUR_DEPLOYED_CONTRACT_ADDRESS> \  
  "addAdmin(address)" <CA_ROOT_WALLET_ADDRESS> \  
  --rpc-url https://api.avax-test.network/ext/bc/C/rpc \  
  --private-key $DEPLOYER_PRIVATE_KEY
```

Trong đó:

- <YOUR_DEPLOYED_CONTRACT_ADDRESS>: Địa chỉ hợp đồng nhận được ở Bước 3.
- <CA_ROOT_WALLET_ADDRESS>: Địa chỉ ví Admin lấy ở Bước 4.2.
- \$DEPLOYER_PRIVATE_KEY: Private Key của ví Deployer đã dùng để triển khai contract.

1.5 Đăng ký và Đăng nhập

Để sử dụng các tính năng yêu cầu cấp và quản lý chứng chỉ, người dùng cần có tài khoản trên hệ thống.

1. Đăng ký tài khoản mới:

- Truy cập vào ứng dụng tại <http://localhost:3000>.
- Bấm vào nút **Đăng ký** trên màn hình.
- Điền thông tin tên đăng nhập và mật khẩu.
- Xác nhận để tạo tài khoản.

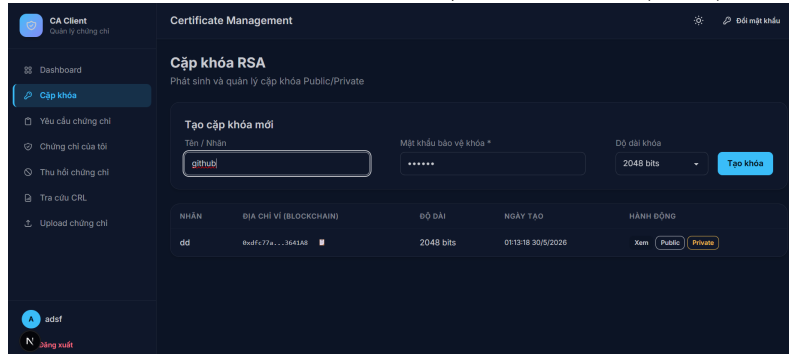
2. Đăng nhập vào hệ thống:

- Tại trang chủ, nhập Username và Password vừa tạo.
- Sau khi đăng nhập, bạn sẽ truy cập vào Dashboard của Client để bắt đầu tạo Cặp khóa và gửi Yêu cầu cấp chứng chỉ.

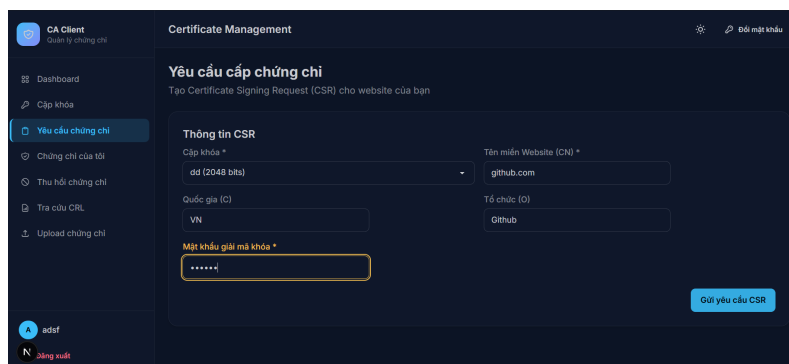
1.6 Quy trình sử dụng dành cho Client

Một client muốn xin cấp chứng chỉ số cần thao tác theo quy trình sau:

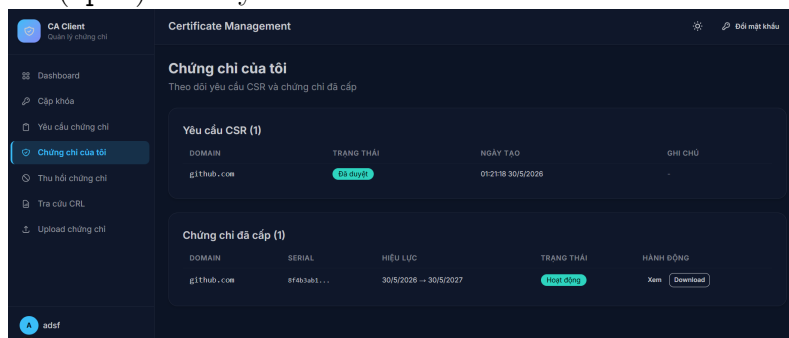
1. **Tạo Cặp Khóa (Key Management):** Vào tab **Cặp khóa**, nhấn **Tạo khóa** để hệ thống sinh ra một cặp Public/Private Key (RSA).



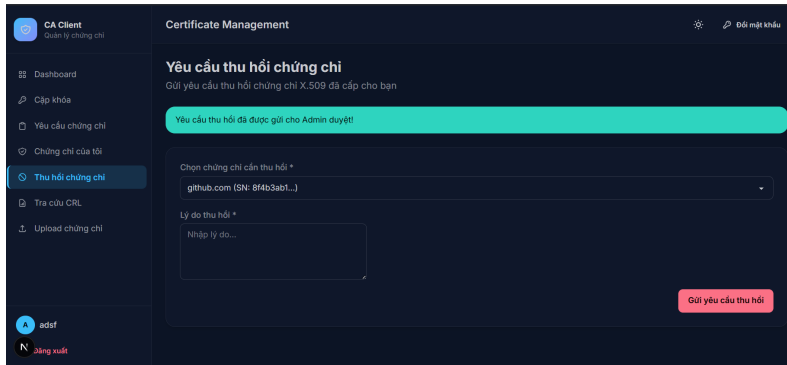
2. **Yêu cầu cấp Chứng chỉ (Create CSR):** Vào menu **Yêu cầu Chứng chỉ**, chọn **Cặp khóa** vừa tạo và nhập thông tin để tạo **CSR**. *Giao dịch này sẽ lưu vết trên Blockchain.*



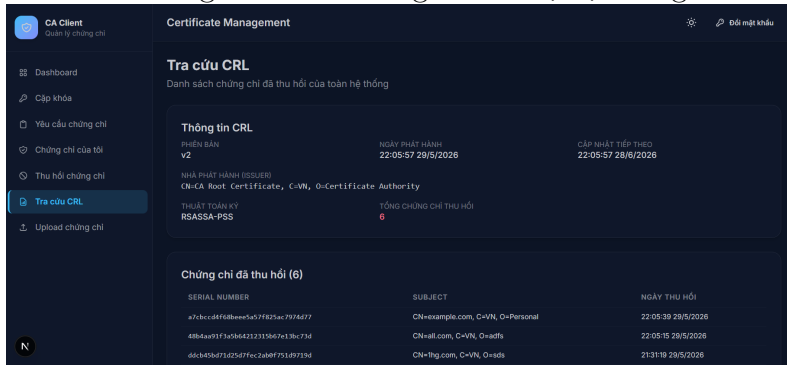
3. **Tải và Quản lý Chứng chỉ:** Sau khi gửi yêu cầu, trạng thái sẽ là “PENDING”. Khi Admin phê duyệt, vào tab **Chứng chỉ của tôi** để xem chi tiết và tải file chứng chỉ (.pem) về máy.



4. **Yêu cầu Thu hồi Chứng chỉ (Revoke):** Nếu nghi ngờ bị lộ Private Key, vào tab **Thu hồi chứng chỉ**, chọn chứng chỉ tương ứng và nhập lý do. Yêu cầu này được gửi đến Admin.



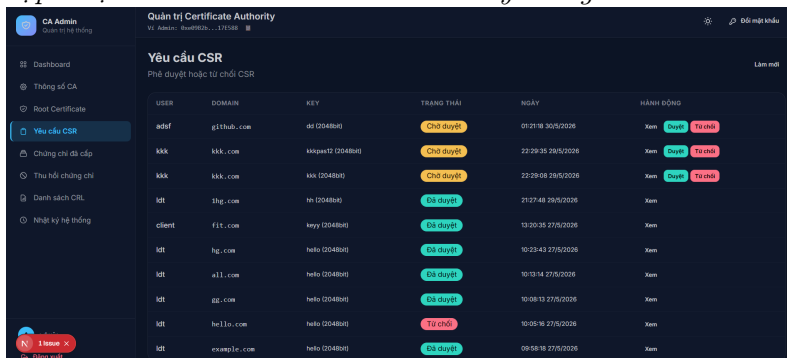
5. **Kiểm tra Danh sách Thu hồi (CRL):** Mục **Tra cứu CRL** cho phép bạn xem danh sách công khai các chứng chỉ đã bị hệ thống thu hồi.



1.7 Quy trình quản trị dành cho Admin

Khi đăng nhập bằng tài khoản admin, bạn có toàn quyền điều hành hệ thống CA:

1. **Duyệt yêu cầu cấp Chứng chỉ (CSR):** Vào mục **Yêu cầu CSR**, nhấn **Phê duyệt** để phát hành chứng chỉ. *Hệ thống sẽ Mint chứng chỉ mới lên Blockchain và cập nhật vào Database. Thao tác này tốn gas của Ví Admin.*



2. **Quản lý toàn bộ Chứng chỉ:** Vào mục **Chứng chỉ đã cấp** để theo dõi toàn bộ chứng chỉ đang hoạt động. Admin có thể chủ động **Thu hồi (Revoke)** hoặc **Gia hạn (Renew)** chứng chỉ. *Thao tác này tốn gas của Ví Admin.*

2 Báo cáo kỹ thuật

2.1 Đặt vấn đề

Trong các hệ thống giao dịch trực tuyến hiện nay, việc đảm bảo tính bảo mật, xác thực và toàn vẹn dữ liệu là yêu cầu bắt buộc. Chứng thư số X.509 là thành phần cốt lõi của hạ tầng khóa công khai (PKI - Public Key Infrastructure), được sử dụng rộng rãi trong giao thức SSL/TLS để thiết lập kênh truyền thông an toàn trên Internet.

Đề án xây dựng một hệ thống Web cho phép:

- Quản lý hạ tầng chứng thư số.
- Cấp phát chứng thư số X.509.
- Thu hồi chứng thư số.
- Quản lý danh sách thu hồi chứng thư (CRL).
- Theo dõi vòng đời của chứng thư số.

Nghiên cứu chuẩn X.509 và xây dựng hệ thống gồm:

- Root Certificate Authority (Root CA).
- Quản lý khóa công khai và khóa bí mật.
- Sinh và ký chứng thư số.
- Quản lý chứng thư đã cấp.
- Quản lý yêu cầu cấp phát chứng thư.
- Quản lý thu hồi chứng thư.

2.2 Phân tích yêu cầu hệ thống

Hệ thống gồm 2 nhóm người dùng:

Admin

- Quản lý hệ thống.
- Sinh Root Certificate.
- Duyệt yêu cầu cấp chứng thư.
- Thu hồi chứng thư.
- Quản lý CRL.
- Theo dõi nhật ký.

Customer

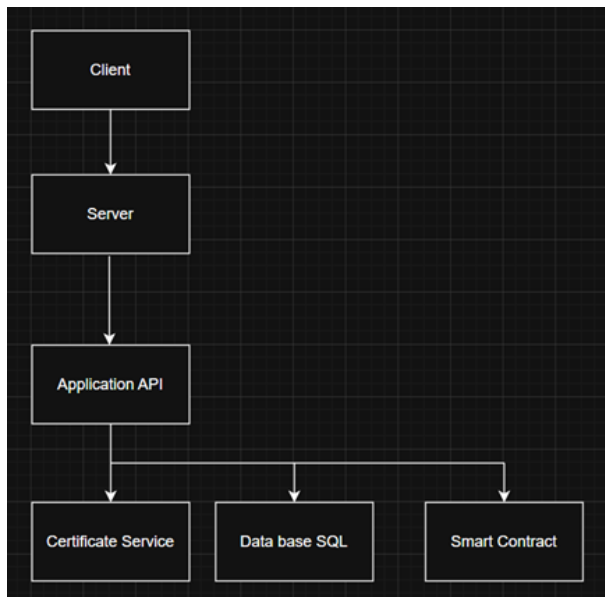
- Đăng ký tài khoản.
- Sinh cặp khóa.
- Tạo CSR.

- Gửi yêu cầu cấp chứng thư.
- Theo dõi trạng thái.
- Yêu cầu thu hồi chứng thư.

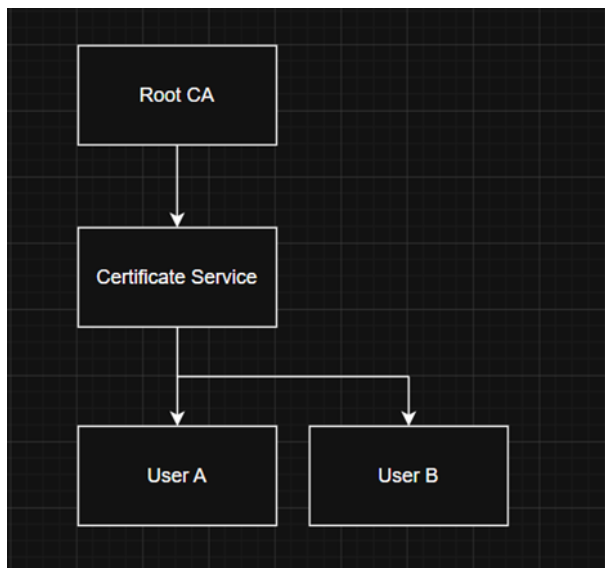
2.3 Thiết kế hệ thống

Kiến trúc tổng thể của hệ thống được xây dựng theo mô hình Web kết hợp với thành phần PKI và blockchain để lưu vết các hoạt động quan trọng.

Kiến trúc PKI



Kiến trúc tổng thể



2.4 Thiết kế chức năng

2.4.1 Đăng ký tài khoản

Luồng xử lý: Người dùng → Đăng ký → Kiểm tra tính đúng đắn dữ liệu → Lưu xuống DB → Hoàn thành.

2.4.2 Sinh cặp khoá RSA

User → Generate Key Pair → RSA → Public Key + Private Key → Lưu DB.

2.4.3 Tạo CSR

User → Nhập Domain → Chọn Public Key → Sinh CSR → Gửi CA.

2.4.4 Phê duyệt chứng thư

Admin → Xem CSR → Kiểm tra thông tin → Phê duyệt → CA ký số → Sinh Certificate.

2.4.5 Thu hồi chứng thư

User → Gửi yêu cầu → Admin duyệt → Certificate Revoked → Cập nhật CRL.

2.5 Công nghệ sử dụng

- Nền tảng & CSDL: Next.js (App Router), SQLite thông qua Prisma ORM.
- Thư viện Mật mã lõi (Off-chain): node-forge xử lý RSA, cấu trúc chuẩn X.509, pkijs, API WebCrypto của NodeJS tối ưu CRL.
- Thư viện Web3 (On-chain): ethers.js kết hợp với kỹ thuật Deterministic Wallet để ký và đẩy giao dịch lên mạng Avalanche Fuji Testnet một cách tự động.

2.6 Bảo mật hệ thống

2.6.1 Bảo mật tài khoản

Mật khẩu người dùng được mã hóa bằng thuật toán BCrypt trước khi lưu vào cơ sở dữ liệu. Hệ thống không lưu mật khẩu dưới dạng văn bản thuần (Plain Text), giúp giảm thiểu rủi ro khi dữ liệu bị rò rỉ.

2.6.2 Xác thực và phân quyền

Hệ thống sử dụng JSON Web Token (JWT) để xác thực người dùng sau khi đăng nhập. Mỗi token chứa thông tin định danh và quyền truy cập của người dùng. Cơ chế phân quyền được áp dụng cho hai vai trò chính:

- Admin: Quản lý hệ thống và chứng thư số.
- Customer: Tạo khóa, gửi yêu cầu cấp phát và quản lý chứng thư cá nhân.

2.6.3 Bảo mật chứng thư số

Hệ thống sử dụng thuật toán RSA 2048 bit để sinh cặp khóa công khai và khóa bí mật. Các chứng thư X.509 được ký bởi CA sử dụng thuật toán **SHA256WithRSA**, đảm bảo tính xác thực và toàn vẹn của chứng thư.

2.6.4 Nhật ký hệ thống

Các hoạt động quan trọng như đăng nhập, cấp phát chứng thư, thu hồi chứng thư và thay đổi thông tin hệ thống đều được ghi nhận vào nhật ký (Audit Log) nhằm hỗ trợ giám sát, kiểm tra và xử lý sự cố bảo mật.

3 Link demo

[Demo hybrid blockchain certificate authority](#)